

Sept.
2026

PENETRATION TESTING REPORT

Mediroza General Hospital

WEB APPLICATION SECURITY ASSESSMENT

Target: <https://medirozahospital.com>

NETWORKWALKS

B082 | WEEK 4 CAPSTONE PROJECT

1. Executive Summary

In this lab, I was given the task of performing a black-box penetration test on Mediroza General Hospital's website at <https://medirozahospital.com>. This assessment was authorized in writing by the customer. The objective was to find weaknesses, show how they could be exploited in the real world, and offer recommendations for strengthening the organization's security posture.

Several vulnerabilities ranging in severity from medium to critical were found throughout the testing process. The most important discovery was that the patient portal login page had a SQL injection vulnerability that let me entirely bypass authentication without knowing any credentials. I was able to see three confidential patient lab report PDFs as a result. I found crucial metadata in one of the files that led to a forgotten database backup stored in a publicly accessible directory on the server after using password cracking software to break the PDF encryption. Ten shareholders' shareholding information and the monthly wages of all thirty-hospital staff were included in this backup.

The target's overall security posture is subpar. With little effort and no specialized equipment, an unauthenticated attacker could access sensitive patient data, employee financial records, and corporation ownership information due to a number of serious vulnerabilities.

Overall Risk Rating: CRITICAL — Immediate remediation is recommended.

2. Scope and Methodology

2.1 Scope

As agreed, upon with the client, the assessment was restricted to the following target domain: <https://medirozahospital.com>

The Social engineering, denial-of-service attacks, and any testing outside the designated domain were not included in the scope.

2.2 Methodology

I used a four-phase, organized black-box penetration testing process.

- ✓ **Reconnaissance:** Passive information collection using web-based resources and publicly accessible data.
- ✓ **Vulnerability Identification:** Examining the behavior of the program to identify input handling and authentication flaws.
- ✓ **Exploitation:** Using controlled exploitation to show the true impact of each vulnerability.
- ✓ **Documentation:** Including all conclusions, supporting data, and recommendations for corrective action in this report.

2.3 Tools utilized

The tools used and their functions are listed in the table below:

Tool	Function/Purpose
Kali Linux & Windows	Operating systems used for reconnaissance activities
Browser developer tools	To examine the behavior of login forms and page sources

wget	To download files from the web server.
Networkwalks Hash Calculator	For extracting password hashes from PDF files.
Networkwalks Password Cracker	Uses wordlists to crack PDF password hashes.
curl -I	A command-line utility for reading web server responses and submitting HTTP requests.
gpdf	To decrypt password-protected PDF files following cracking.
exiftool	To reading hidden metadata from PDF files.
ChatGPT	To transform unprocessed SQL data into comprehensible tables

3. Findings and Proof of Exploitation

3.1 Summary Table

I identified the following vulnerabilities based on the data gathered during reconnaissance and footprinting activities.

#	Vulnerability	Location	Risk
1	Username enumeration on login page	patient/login.php	Medium
2	SQL injection login bypass	patient/login.php	Critical
3	Encrypted PDFs accessible after login bypass	patient/reports/	High
4	Weak PDF passwords crackable with a wordlist	patient_report_*.pdf	High
5	Sensitive metadata left in patient PDF files	patient_report_3.pdf	Medium
6	Forgotten backup folder with directory listing enabled	old/	Critical
7	Confidential staff salaries and shareholder data in plain text	old/mediroza_db_backup_2019.sql	Critical

3.2 Finding 1: Username Enumeration

Risk Rating: Medium

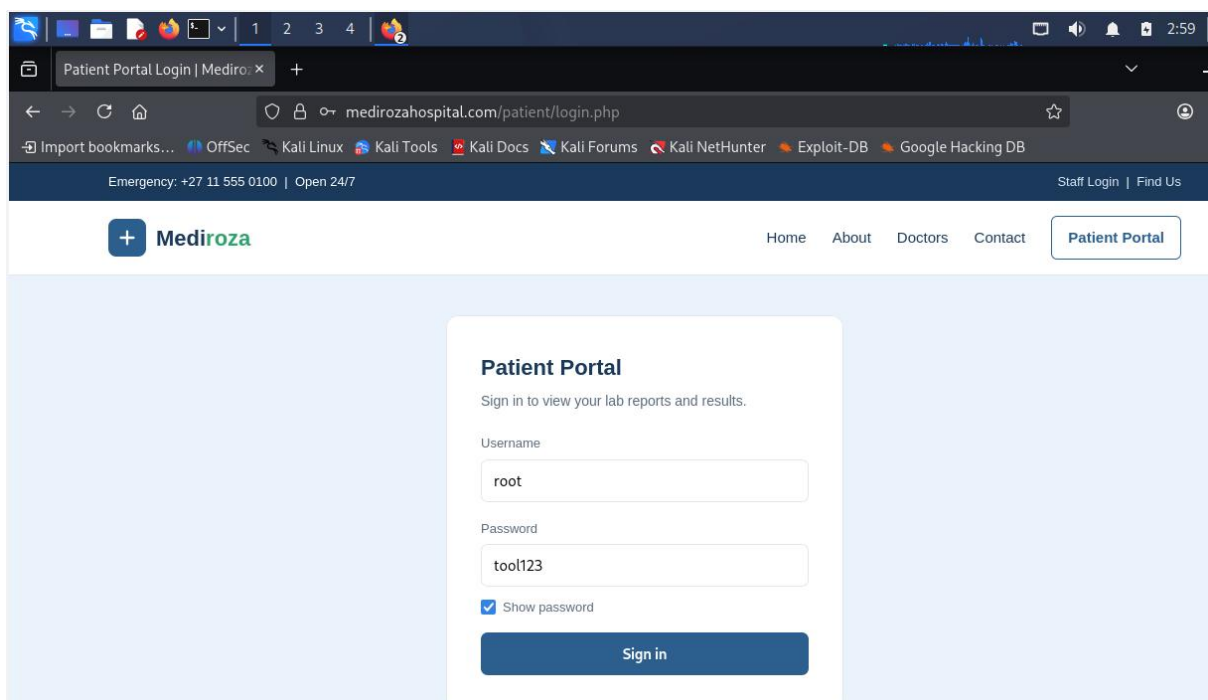
Location: patient/login.php

Description

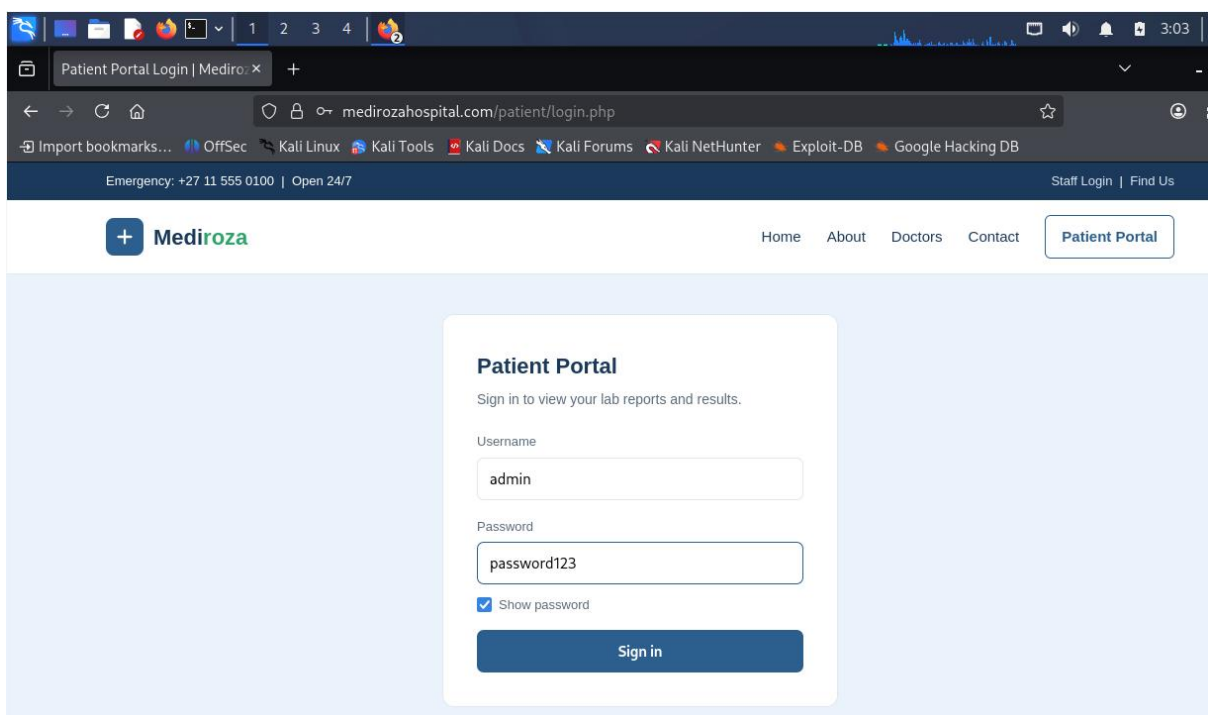
When a login page indicates if a username exists or not by displaying distinct error messages for incorrect usernames and passwords, this is known as username enumeration. To prevent an attacker from verifying legitimate usernames, a secure login should consistently display the same generic message in both scenarios.

Actions Taken

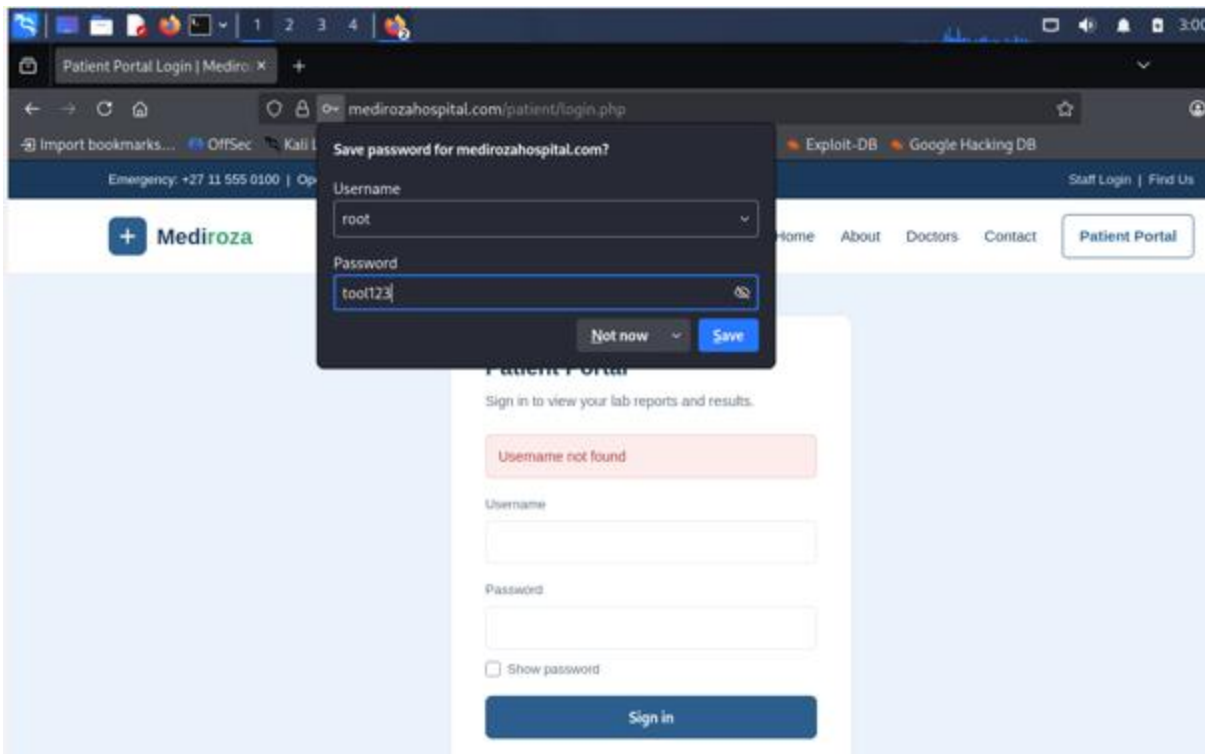
I opened the patient portal login page and tested the error messages by entering several inputs. I started by entering a username that I thought wouldn't exist, as per the below screen shots.



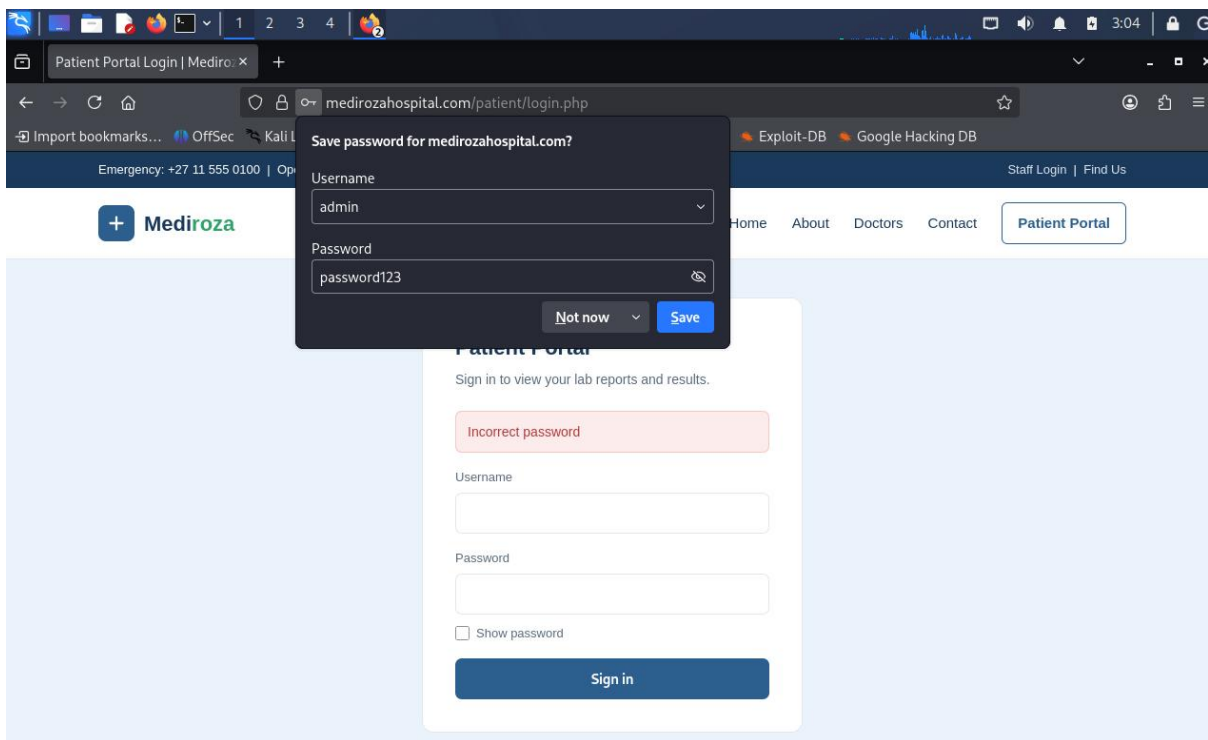
I then I tried with a common default username, as shown below:



The responses were as follows:



Username not found



Incorrect password

The two distinct notifications that the website displayed above verified that admin is a legitimate account on the system. Now that I had the username, all I had to do was figure out the password.

3.3 Finding 2: SQL Injection Login Bypass

Risk Rating: Critical

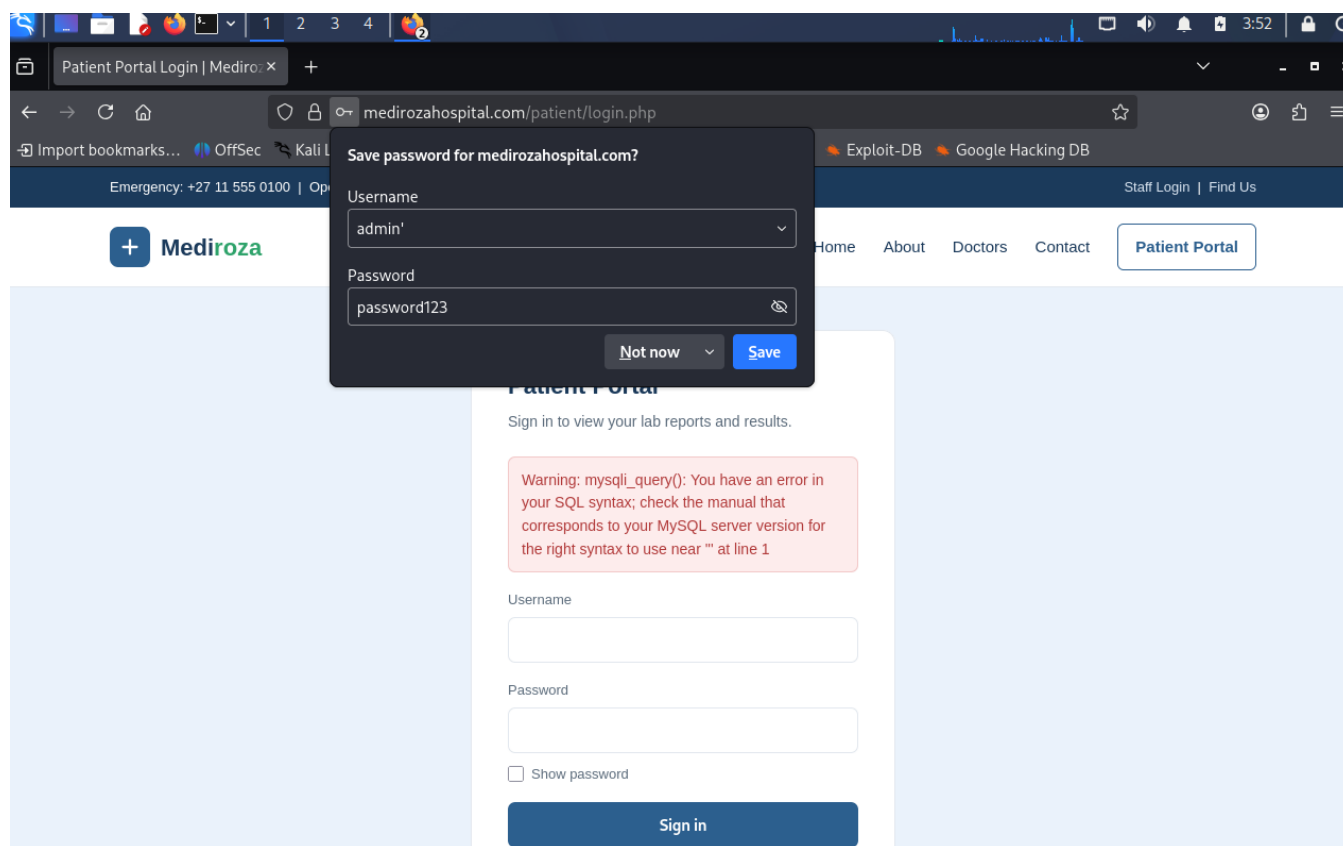
Location: patient/login.php

Description

An application that inserts user input straight into a database query without first sanitizing it is known as SQL injection. An attacker can alter the query's behavior by inserting SQL code into the input field. In this instance, I was able to enter in as administrator without knowing the password by completely commenting out the password check.

Actions Taken

I typed a single quote in the username field to check for SQL injection, as shown below:

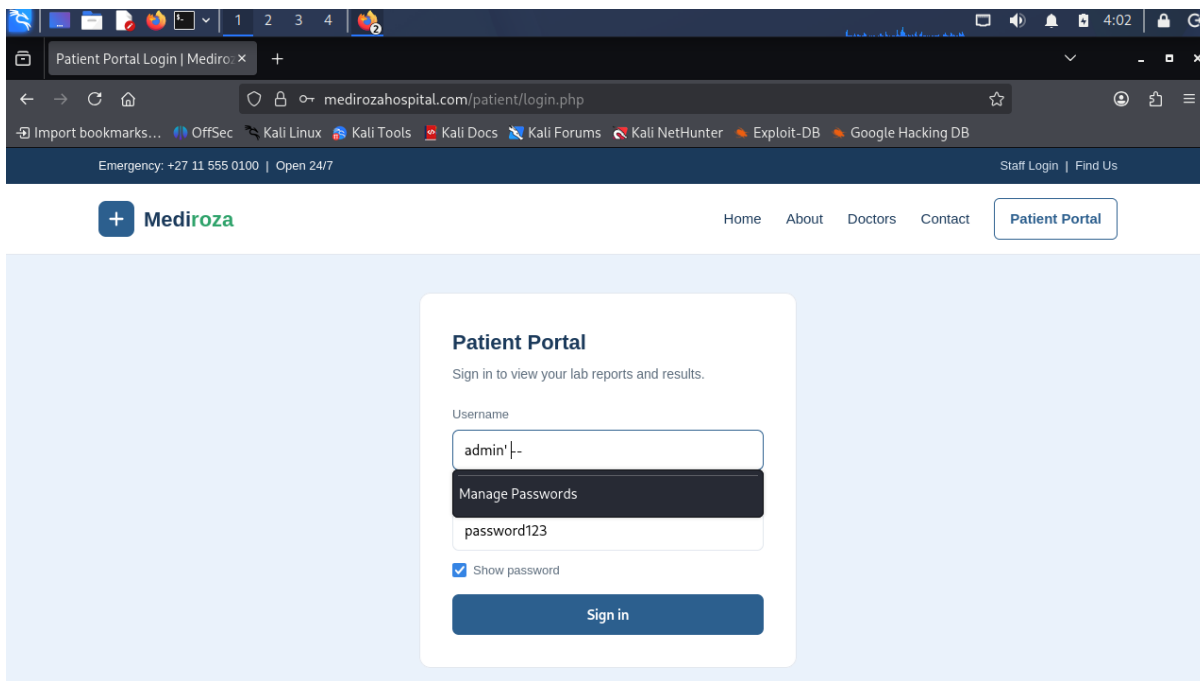


The above database fault verified that the field could be injected. This is how the application was constructing its SQL query in the background.

```
SELECT * FROM users WHERE username='admin' AND password='password123'
```

The extra quote broke the query and caused the error. I then crafted the classic SQL injection bypass payload.

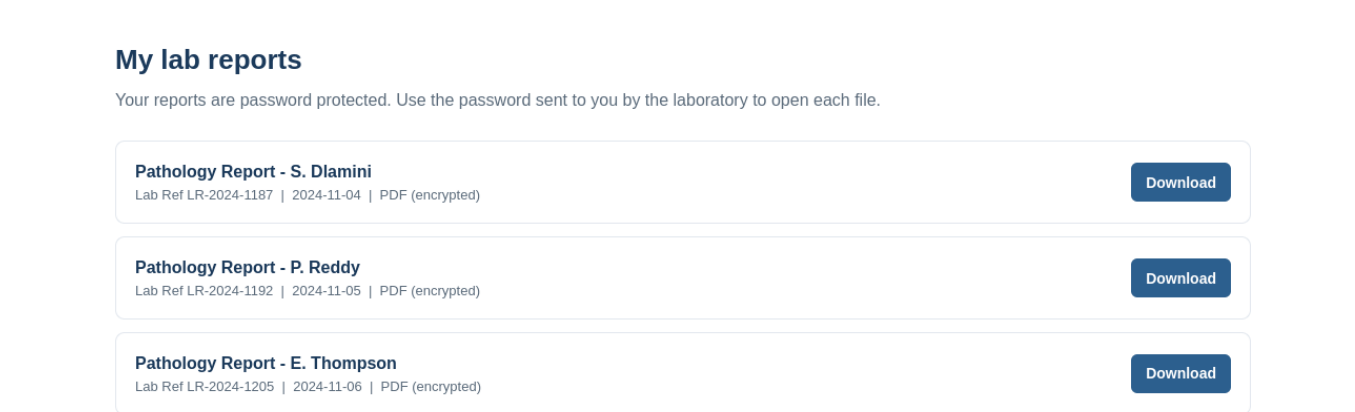
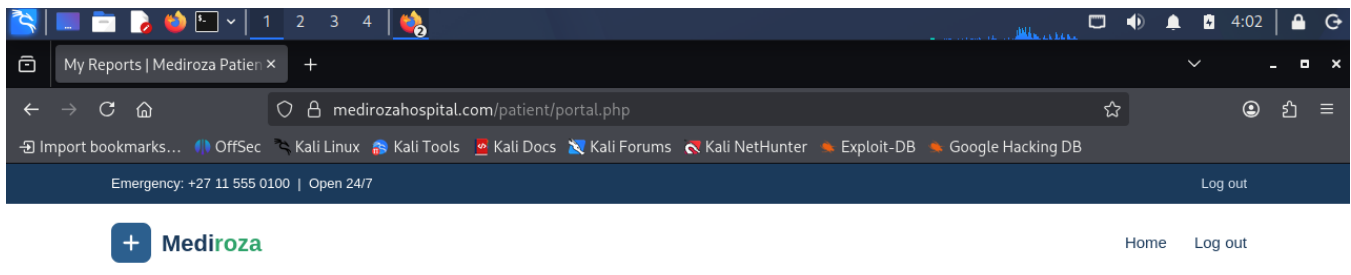
```
username: admin' -- password: password123
```



The -- comments out everything after it in SQL, so the query becomes.

```
SELECT * FROM users WHERE username='admin'
```

The password check is ignored completely. The query returns the admin row and I am logged in as per the below screenshot.



Milestone 1 successfully achieved.

3.4 Finding 3: Confidential PDFs Accessible After Login Bypass

Risk Rating: High

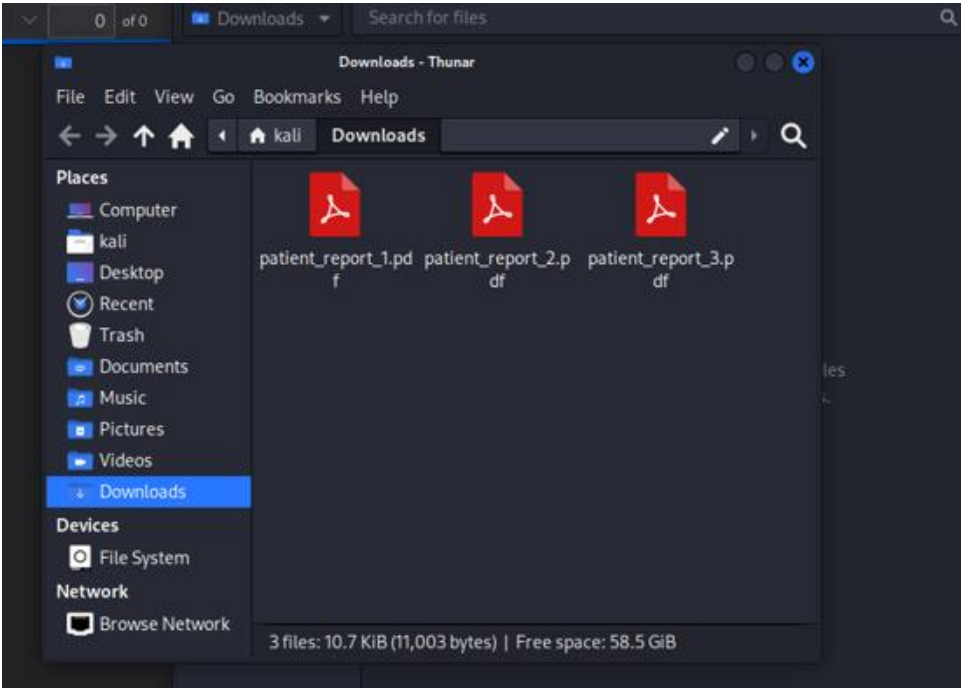
Location: patient/reports/

Description

After gaining unauthorised access to the portal through SQL injection, I found three patient lab report PDFs available for download. These are confidential medical records that should only be accessible to the named patients and their doctors.

Actions Taken

After logging in with the SQL injection payload I was directed to the patient portal which listed the following PDF files: *patient_report_1.pdf*; *patient_report_2.pdf*; and *patient_report_3.pdf*. I then downloaded all three files as shown below:



3.5 Finding 4: Weak PDF Passwords Crackable using a Wordlist

Risk Rating: High

Description

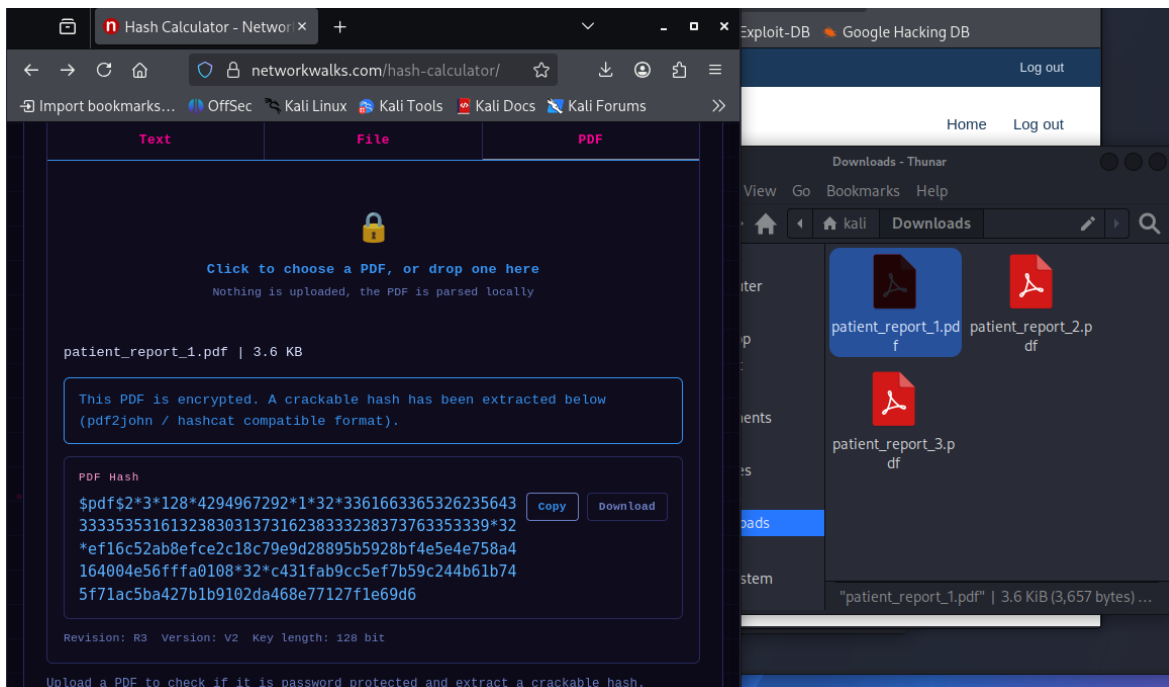
Each of the three PDFs had a password. However, the passwords were easy to crack with automated tools because they were weak and appeared in widely accessible password wordlists. Sensitive medical records are not significantly protected when simple passwords are used.

Targeted Files

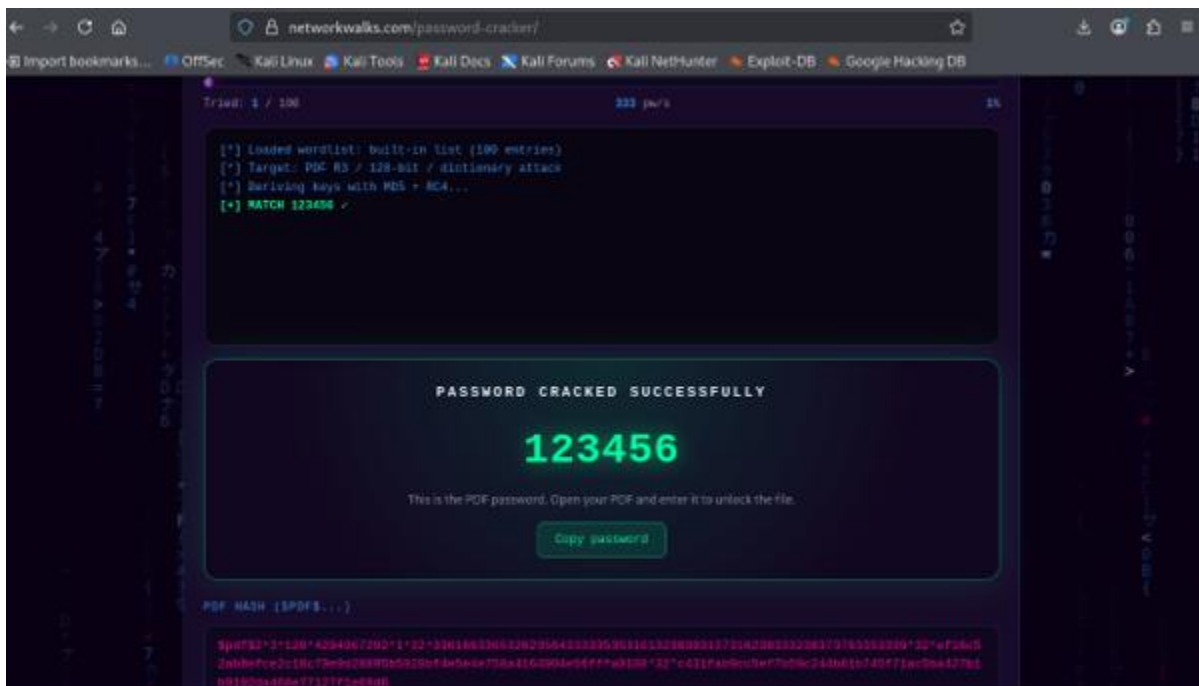
Files	Password cracked	Status
patient_report_1.pdf	123456	Password successfully cracked ✓
patient_report_2.pdf	password	Password successfully cracked ✓
patient_report_3.pdf	!@#\$%^&	Password successfully cracked ✓

Actions Taken

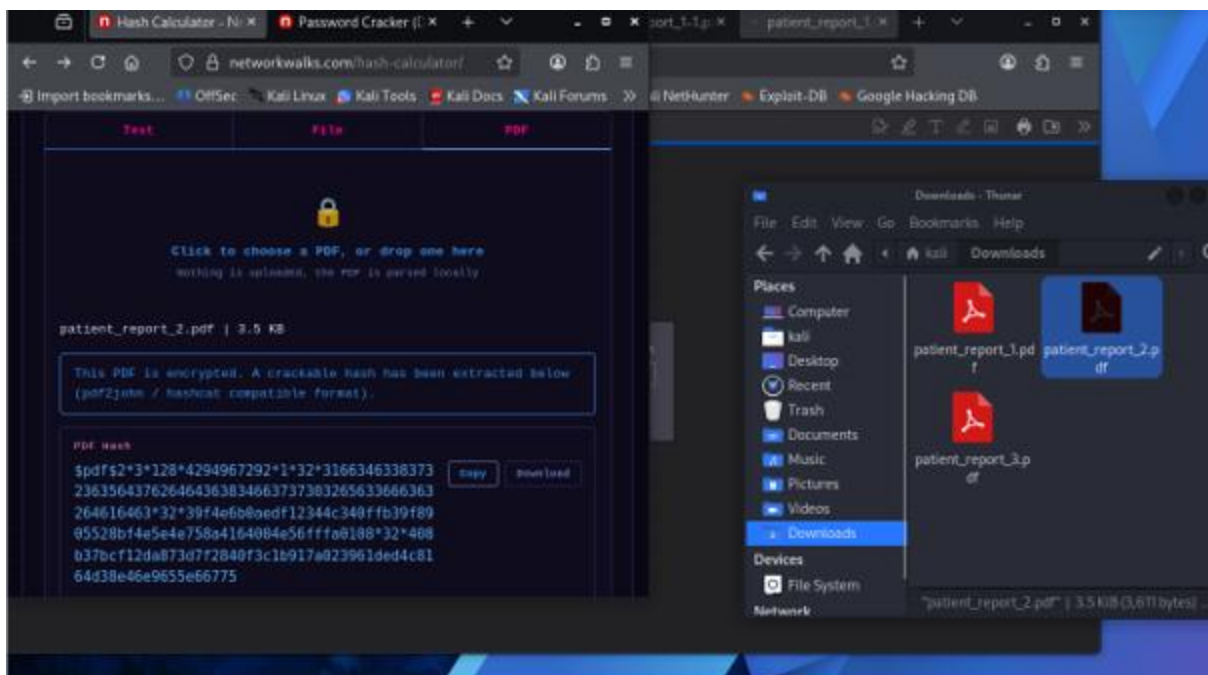
I extracted a crackable hash from each PDF using the Networkwalks Hash Calculator, I then ran each hash through the Networkwalks Password Cracker. Using the built-in 100-word default wordlist, reports 1 and 2 cracked right away, see the screenshot.



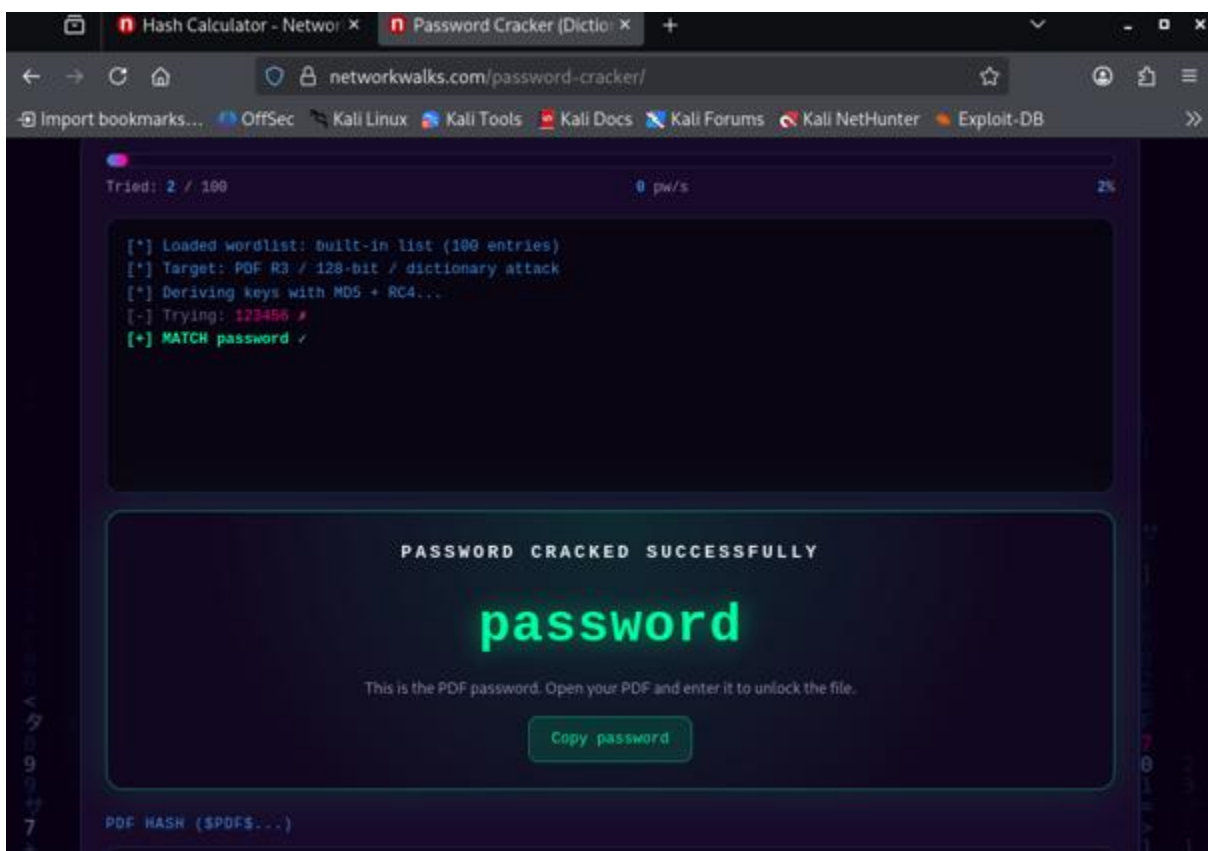
Hash for patient_report_1.pdf



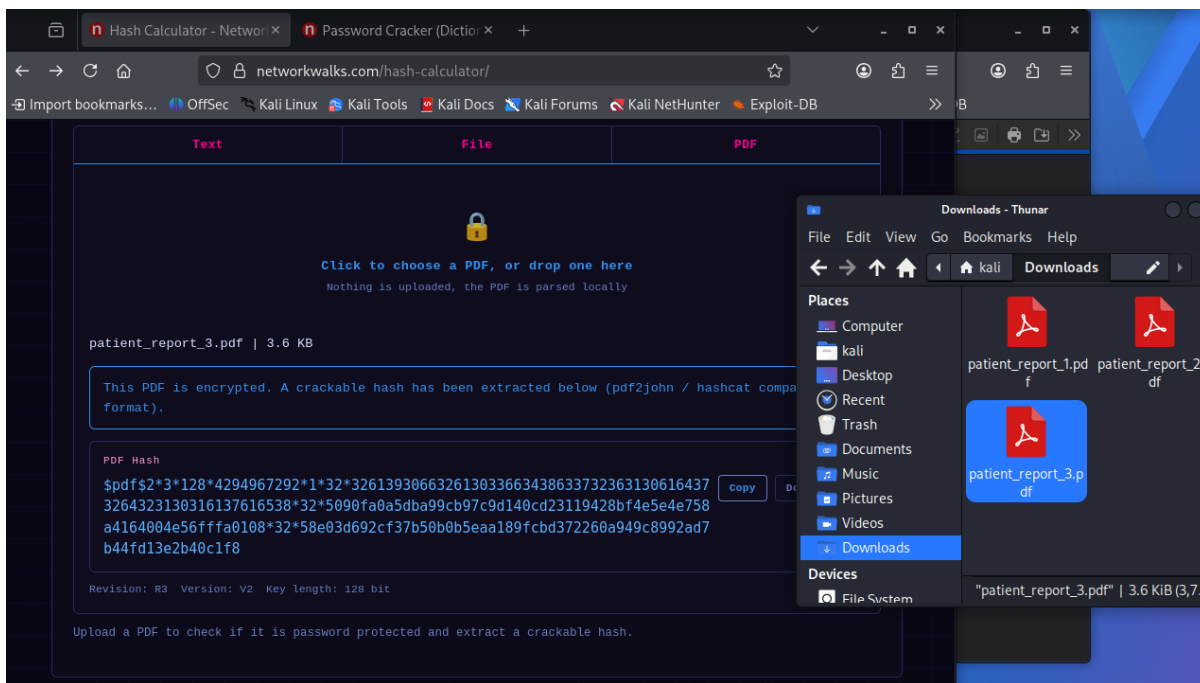
Password successfully cracked for: patient_report_1.pdf



Hash for patient_report_2.pdf

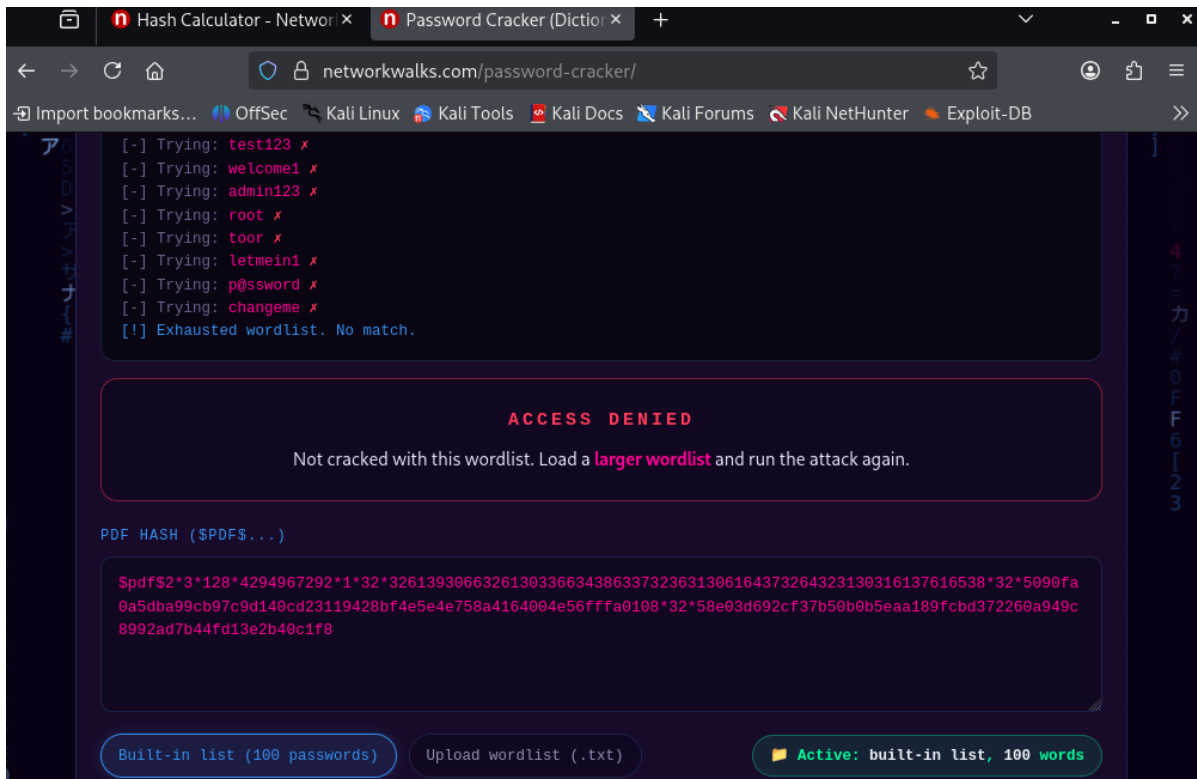


Password successfully cracked for: patient_report_2.pdf

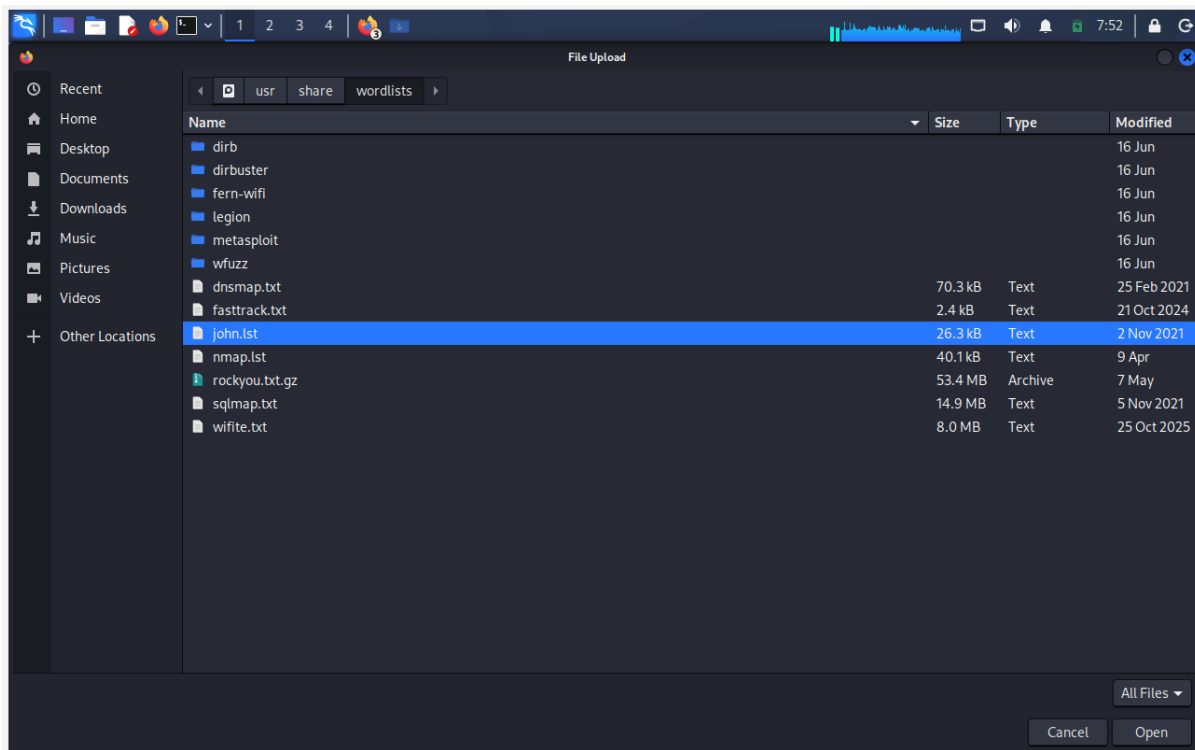


Hash for patient_report_3.pdf

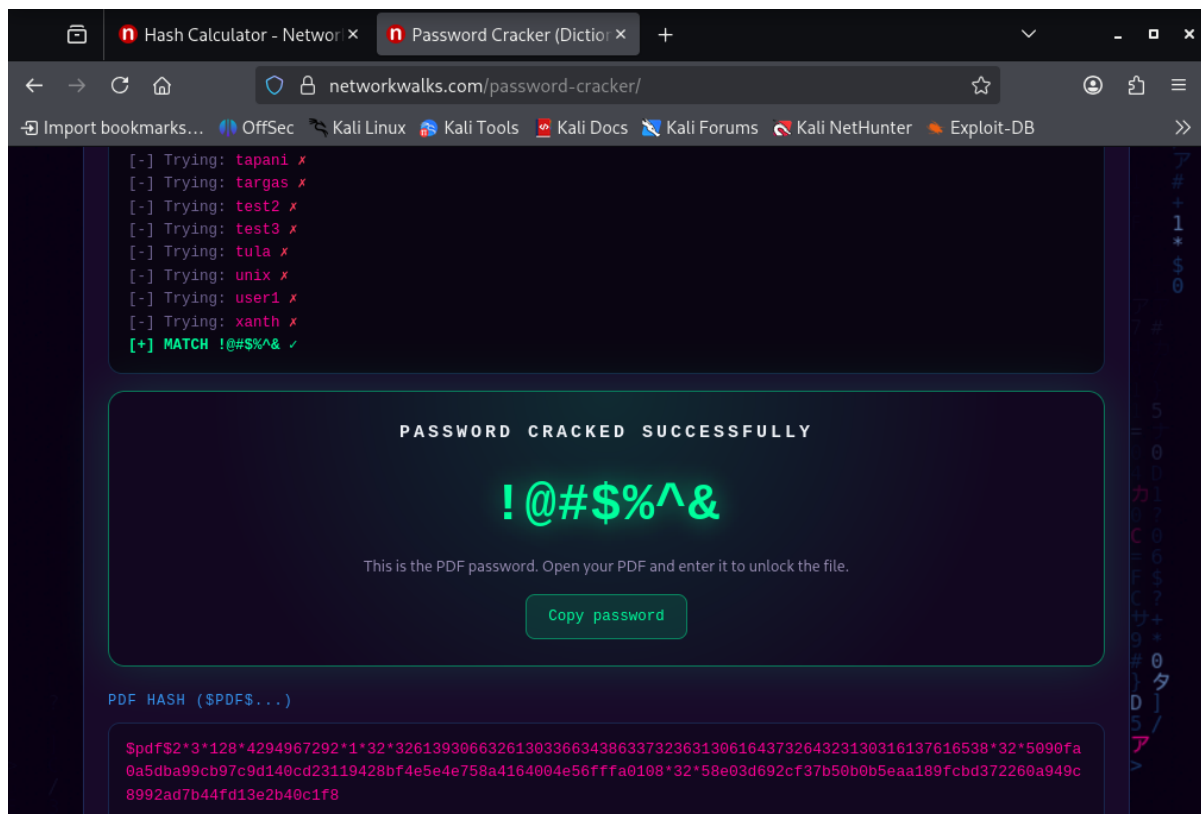
The built-in list did not work for Report 3. I performed the attack with a larger wordlist (the JTR default password list) as shown below:



The password for patient_report_3.pdf could not be cracked using the built-in list.



Adding john.lst wordlist to the networkwalks password-cracker tool



Password successfully cracked for: patient_report_3.pdf

I then opened each PDF with its cracked password and read the confidential patient medical records as per the screenshots below:

The screenshot shows a PDF viewer window titled "patient_report_1.pdf — Pathology Report - S. Dlamini". The report is from Mediroza General Hospital, located at 14 Cedar Avenue, Johannesburg, South Africa. The report is labeled "CONFIDENTIAL".

Patient Information:

- Patient Name: Siphso Dlamini
- Patient ID: MG-P-10231
- Date of Birth: 1984-06-12
- Gender: Male
- Report Date: 2024-11-04
- Referring Dr: Dr. Anita Naicker
- Specimen: Whole blood (EDTA)
- Lab Ref No: LR-2024-1187

Pathology Laboratory Report Results:

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Results for patient_report_1.pdf

The screenshot shows a PDF viewer window titled "patient_report_2.pdf — Pathology Report - P. Reddy". The report is from Mediroza General Hospital, located at 14 Cedar Avenue, Johannesburg, South Africa. The report is labeled "CONFIDENTIAL".

Patient Information:

- Patient Name: Priya Reddy
- Patient ID: MG-P-10244
- Date of Birth: 1991-02-28
- Gender: Female
- Report Date: 2024-11-05
- Referring Dr: Dr. Johan van der Merwe
- Specimen: Serum
- Lab Ref No: LR-2024-1192

Pathology Laboratory Report Results:

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Results for patient_report_2.pdf



Results for patient_report_3.pdf

Milestone 2 successfully achieved.

3.6 Finding 5: Sensitive Metadata in Patient PDF Files

Risk Rating: Medium

Description

Hidden metadata, including the author's identity, the creation date, and personalized remarks, are stored in PDF files. Exiftool and other tools can be used to extract this metadata, which is not accessible when just reading the document. In this instance, the IT administrator's internal staff comment in report 3 explicitly linked to a confidential backup file on the server.

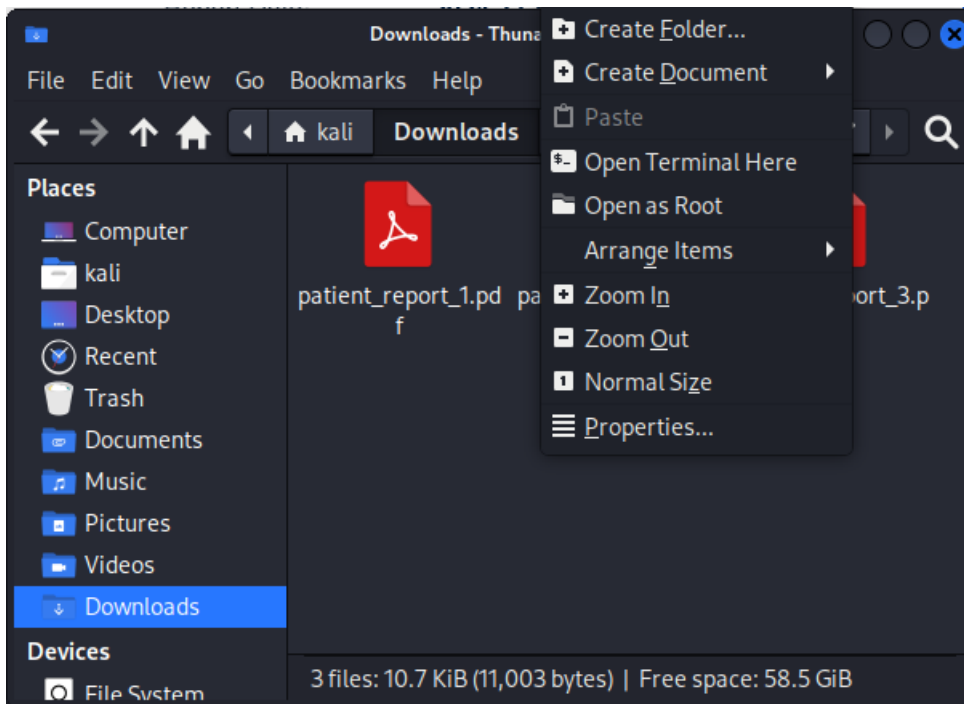
Actions Taken

To enable exiftool to access all metadata fields, I first used qpdf to decode all three reports. Only the encryption type is visible in a locked PDF.

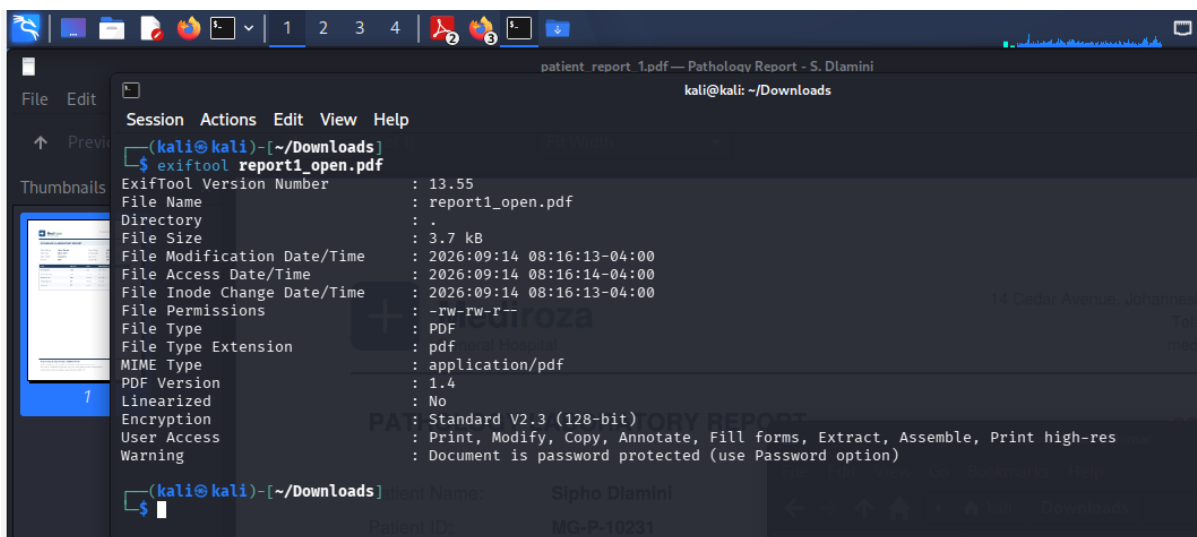
```
qpdf --password='123456' --decrypt patient_report_3.pdf report3_open.pdf
```

I then used exiftool on the file that had been unlocked.

```
exiftool report1_open.pdf
```



Clicked on Open Terminal Here.



Exiftool report1_open.pdf

KEY FIELDS IN THE OUTPUT FOR REPORT 3

```
Author      : j.malik
Comments    : DB backup moved to /old before site migration, do not delete
```

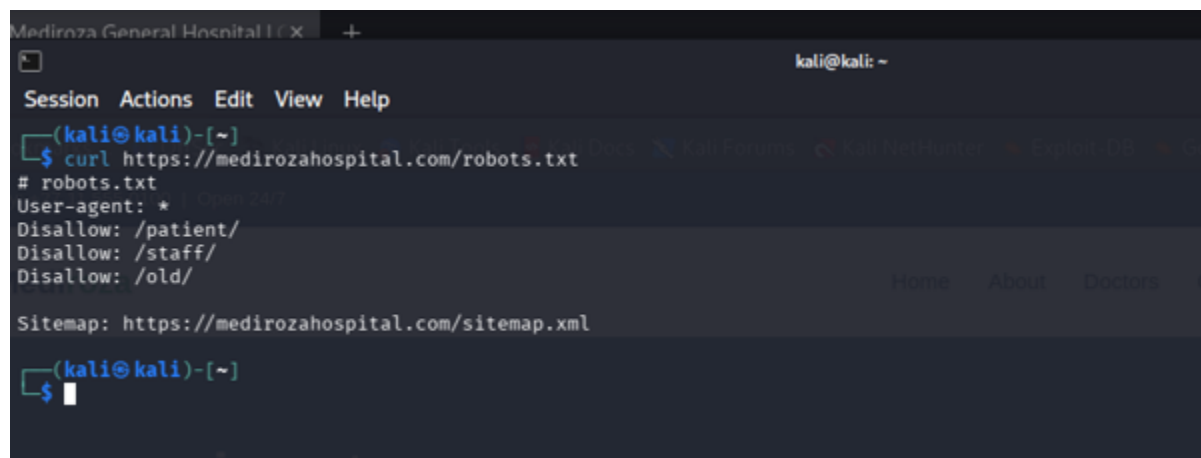
This comment was left by the IT administrator Jameel Malik (j.malik) and revealed the exact location of a database backup on the server.

3.7 Finding 6: Forgotten Backup Folder with Directory Listing Enabled

Risk Rating: Critical

Description

When there is no index page, a web server misconfiguration known as "directory listing" shows the contents of a folder like a file browser. Anyone who accessed the /old folder on the system could see a database backup file since directory listing was enabled. This folder was mentioned as a prohibited route in the robots.txt file, which I had discovered during my initial recon.



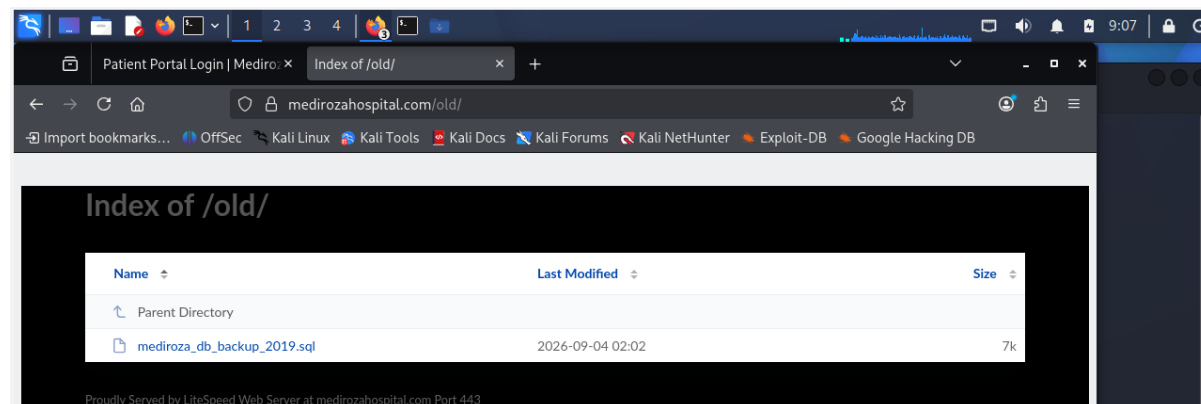
```
Mediroza General Hospital | X +
kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ curl https://medirozahospital.com/robots.txt
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml
(kali@kali)-[~]
$
```

Actions Taken

I made a note of /old in the robots file during recon. Finding 5's metadata hint verified that this was the backup's location. I used the browser to open the folder. <https://medirozahospital.com/old/>

I was able to view the backup file right away because the directory listing was enabled, see below screenshot. mediroza_db_backup_2019.sql, I then downloaded the file using wget. https://medirozahospital.com/old/mediroza_db_backup_2019.sql



3.8 Finding 7 — Confidential Staff Salaries and Shareholder Data in Plain Text

Risk Rating: Critical

Description

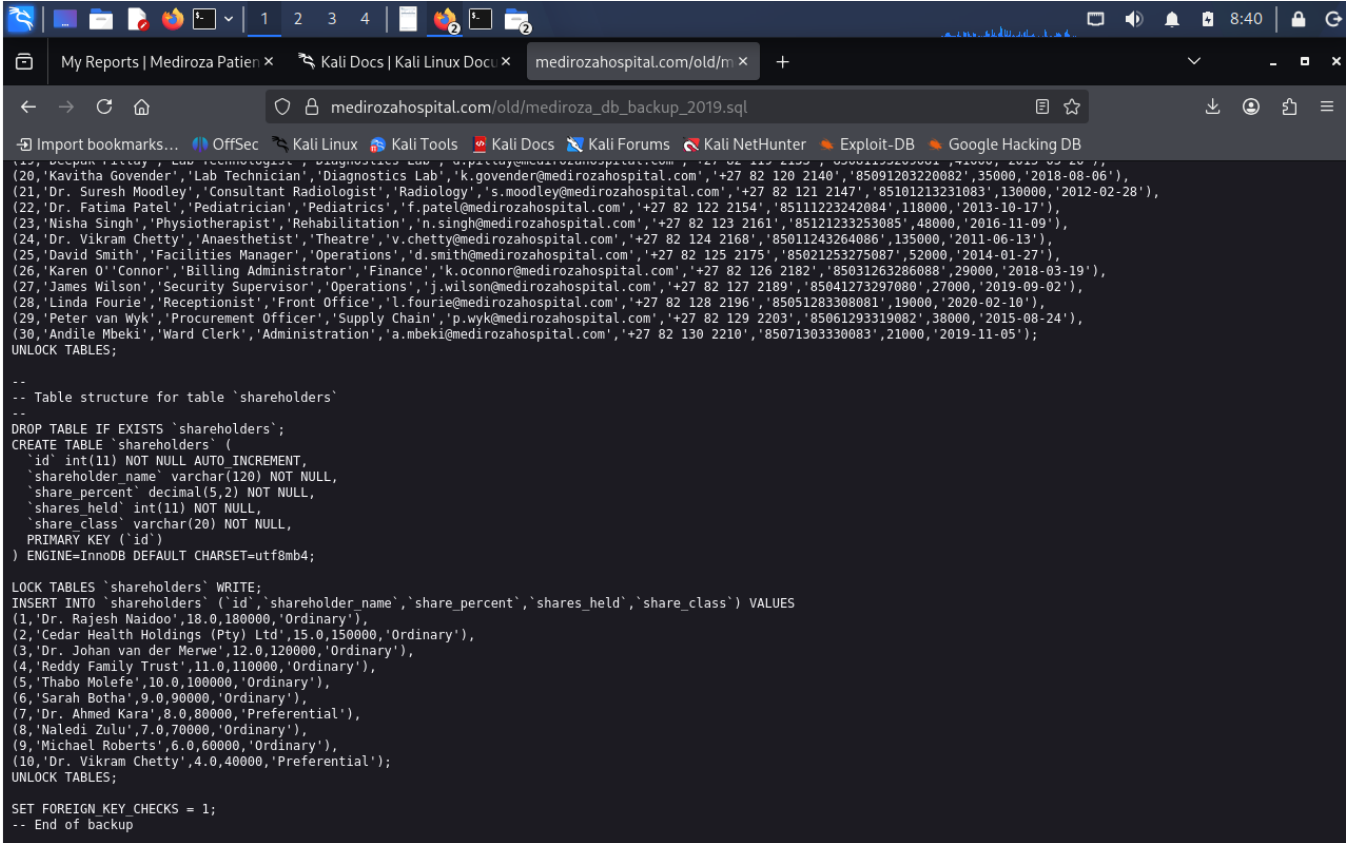
All thirty hospital employees' full names, job titles, email addresses, phone numbers, national ID numbers, and monthly salaries in ZAR were included in the database backup, which contained extremely sensitive

information in plain text. The names and percentages of each of the hospital's ten stockholders were also included. Anyone who accessed the /old folder could view this information, which was unprotected.

Actions Taken

I used a text editor to open the SQL file. The format of the data was raw SQL. I created a readable table using ChatGPT. I was able to view the ownership structure of the entire hospital as well as each employee's private compensation, please refer to the screenshots below.

Additionally, I verified that Jameel Malik, the IT Systems Administrator mentioned in the staff table, matches the Author field in the PDF metadata, j.malik. This creates a single attack chain that links all three milestones.



1	Shareholder Name	Share Percentage	Share Class
2	Dr. Rajesh Naidoo	18.00%	Ordinary
3	Cedar Health Holdings (Pty) Ltd	15.00%	Ordinary
4	Dr. Johan van der Merwe	12.00%	Ordinary
5	Reddy Family Trust	11.00%	Ordinary
6	Thabo Molefe	10.00%	Ordinary
7	Sarah Botha	9.00%	Ordinary
8	Dr. Ahmed Kara	8.00%	Preferential
9	Naledi Zulu	7.00%	Ordinary
10	Michael Roberts	6.00%	Ordinary
11	Dr. Vikram Chetty	4.00%	Preferential
12	Total	100.00%	

No.	Name	Job Title	Department	Monthly Salary (ZAR)
1.	Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	R138,000
2.	Sarah Botha	Chief Financial Officer	Finance	R152,000
3.	Dr. Johan van der Merwe	Medical Director	Management	R160,000
4.	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	R132,000
5.	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	R128,000
6.	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	R74,000
7.	Michael Roberts	HR Director	Human Resources	R96,000
8.	Susan Pretorius	HR Officer	Human Resources	R32,000
9.	Jameel Malik	IT Systems Administrator	IT	R58,000
10.	Thabo Molefe	Network Engineer	IT	R46,000
11.	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	R34,000
12.	Lerato Mokoena	Registered Nurse	Pediatrics	R33,000
13.	Bongani Ndlovu	Registered Nurse	Cardiology	R35,000
14.	Zanele Mahlangu	Nursing Sister	Theatre	R42,000
15.	Kagiso Sithole	Pharmacist	Pharmacy	R61,000
16.	Naledi Zulu	Pharmacy Assistant	Pharmacy	R26,000
17.	Themba Nkosi	Radiographer	Radiology	R44,000
18.	Palesa Radebe	Radiographer	Radiology	R43,000
19.	Deepak Pillay	Lab Technologist	Diagnostics Lab	R41,000
20.	Kavitha Govender	Lab Technician	Diagnostics Lab	R35,000
21.	Dr. Suresh Moodley	Consultant Radiologist	Radiology	R130,000
22.	Dr. Fatima Patel	Pediatrician	Pediatrics	R118,000
23.	Nisha Singh	Physiotherapist	Rehabilitation	R48,000
24.	Dr. Vikram Chetty	Anaesthetist	Theatre	R135,000
25.	David Smith	Facilities Manager	Operations	R52,000
26.	Karen O'Connor	Billing Administrator	Finance	R29,000
27.	James Wilson	Security Supervisor	Operations	R27,000
28.	Linda Fourie	Receptionist	Front Office	R19,000
29.	Peter van Wyk	Procurement Officer	Supply Chain	R38,000
30.	Andile Mbeki	Ward Clerk	Administration	R21,000

Milestone 3 successfully achieved.

4. Complete Overview of the Attack Chain

- ✓ **Task 1:** Robots.txt revealed three hidden folders: /patient, /staff, and /old.
- ✓ **Task 2:** The patient login page verified that the admin was a legitimate account by displaying various error messages for incorrect usernames and passwords. **(Finding 1)**
- ✓ **Task 3:** SQL injection was confirmed when a single quote in the username field triggered a database error. **(Finding 2)**

- ✓ **Task 4:** The payload admin' -- bypassed the login entirely and gave access to the patient portal. **(Finding 2)**
- ✓ **Task 5:** 3 confidential patient PDF lab reports were downloaded from the portal. **(Finding 3)**
- ✓ **Task 6:** Wordlists were used by the Networkwalks Password Cracker to crack the PDF passwords. The built-in list was utilized in Reports 1 and 2. A larger JTR list was required for Report 3. **(Finding 4)**
- ✓ **Task 7:** exiftool on the unlocked report 3 revealed a hidden comment by j.malik pointing to /old. **(Finding 5)**
- ✓ **Task 8:** The /old folder had directory listing enabled, exposing the database backup. **(Finding 6)**
- ✓ **Taks 9:** Thirty employees' salary and ten shareholders' shareholding information were included in plain text in the backup. **(Finding 7).**

5. Recommendations and Remediation

5.1 Fix Username Enumeration

Regardless of whether the username or password was incorrect, change the login page to display a single generic message for every unsuccessful login attempt. For instance: "Incorrect credentials. Please give it another go."

5.2 Fix SQL Injection

Use a prepared statement or parameterized query in place of the current login query. This separates the SQL code from the user input so that no amount of crafted input can change the query structure. This is the most important fix in this report.

```
// Safe example using PHP PDO prepared statement $stmt = $pdo->prepare("SELECT * FROM users
WHERE username = ? AND password = ?") $stmt->execute([$username, $password])
```

5.3 Fix PDF Access and Password Strength

To prevent the web server from serving the PDF files directly, move them outside of the web root. Enforce access through a server-side script that checks authentication before serving any file. If passwords are used, make sure they are at least 12 characters long and contain a combination of capital, lowercase, numeric, and symbol characters.

5.4 Strip PDF Metadata

Before releasing files, remove all metadata. Internal remarks or staff notes should never be kept in files that are exported from the company. To remove all metadata, use the following command. Exiftool -all= patient_report_3.pdf.

5.5 Fix Directory Listing and Remove the Backup

Add Options -Indexes to the Apache configuration or .htaccess file to disable directory listing on all folders. Immediately remove the database backup from the /old folder. Backups of databases should never be kept at the web root. Store them in a private, access-controlled location outside the publicly accessible part of the server.

6. Conclusion

A full attack chain from the login page to extremely sensitive internal data was discovered during this assessment. There was no need for advanced tool or expertise. Every vulnerability identified in this research is well-known and has established remedies. Before the system is utilized to store or provide actual patient data, I recommend the client to address all Critical and High findings immediately.

Moreover, this lab made it easier for me to comprehend how password cracking works and why it's crucial to use strong passwords for security. I also discovered that short or common passwords are easily cracked, which further highlights the need for strong passwords.

~~~~~**END**~~~~~

 **Submitted by:** Iyaloo Shivute

 **Cybersecurity Mentor:** Waqas Karim, CCIE

 **Organisation:** Networkwalks

Batch B082 | Week 4 Capstone Project

LinkedIn: [www.linkedin.com/in/iyaloo-shivute](https://www.linkedin.com/in/iyaloo-shivute)

---

### Project Information

**Program Name:** Cybersecurity program at Networkwalks | **Week:** 04 | **Repository:** GitHub